

NIST SP 800-30 Rev

NIST SP 800-30 Rev. 1

Guide to assessing risk

NIST SP 800-30 is a publication that provides guidance on performing risk assessments. It outlines strategies for identifying, analyzing, and remediating risks. Organizations use NIST SP 800-30 to gain insights into the potential likelihood and severity of risks—helping them make informed decisions about allocating resources, implementing controls, and prioritizing remediation efforts.

This four page document is adapted from NIST SP 800-30 Rev. 1. The term "Rev. 1" signifies that it is the first updated version of this publication. NIST occasionally revises its documents to incorporate new information, reflect changes in technology and regulatory requirements, or address feedback.

Note: NIST's [Computer Security Resources Center](#) contains more information on SP 800-30 Rev. 1.

Threat sources

NIST SP 800-30 defines and categorizes threat sources as entities or circumstances that can negatively impact an organization's information systems. This information is useful for identifying and assessing potential risks. When referencing it, consider the intent/capabilities of either internal and external threat sources.

Note: The following table lists a few possible *threat sources* that could compromise a publicly accessible database server.

Type	Examples	Description
Human	<i>Standard user</i> - Employee - Customer <i>Privileged user</i> - System administrator <i>Group</i> - Competitor - Supplier - Business partner - Nation state <i>Outsider</i> - Hacker - Hackivist - Advanced persistent threat (APT)	Threats arising from individuals or groups who might purposefully or accidentally exploit cyber resources. For example, they might alter data in a way that negatively impacts the company. Alternatively, they might intentionally steal data and damage business equipment.

Technological	<i>Hardware</i> • Storage • Processing • Communications <i>Software</i> • Operating system(s) • Networking • Malicious software	Threats that originate from non-human factors. For example, failures of equipment due to aging, resource depletion, or other circumstances.
Environmental	<i>Operational environment</i> • Temperature controls • Humidity controls • Faulty power supplies <i>Natural hazards</i> • Power outages • Extreme weather events	Threats that arise from accidental, non-human factors. For example, equipment failures caused by the operational environment.

Threat events

NIST SP 800-30 defines and categorizes threat events as actual instances where a threat source exploits a vulnerability and causes damage or harm to an organization's information systems. This information is useful for gaining insights into the types of risks that assets face. More effective controls and countermeasures can be identified by understanding possible threat events,

Note: The following table lists just a few possible *threat events* that could compromise a publicly accessible database server.

Examples	Description
Perform reconnaissance and surveillance of organization	Threat source examines and assesses the company's vulnerabilities over time using various tools (e.g., scanning, physical observation).
Obtain sensitive information via exfiltration	Threat source installs malicious software on organizational systems to locate and acquire sensitive information.
Alter/Delete critical information	Threat source alters or deletes data that is critical to day-to-day business operations.

Craft counterfeit certificates.	Threat source compromises a certificate authority to make their connections appear legitimate.
Install persistent and targeted network sniffers on organizational information systems.	Threat source installs software designed to collect (sniff) network traffic over a continued period of time.
Conduct Denial of Service (DoS) attacks.	Threat source sends automated, excessive requests to overwhelm the system's operating capabilities.
Disrupt mission-critical operations.	Threat source compromises the integrity of information in such a way that prevents the business from carrying out critical operations.
Obfuscate future attacks.	Threat source takes actions to inhibit the effectiveness of the intrusion detection systems or auditing capabilities at the company.
Conduct "man-in-the-middle" attacks.	Threat source eavesdrops on sessions between internal and external systems. Later, they relay messages between organizational and external systems that make them believe they're talking directly to each other over a private connection.

Likelihood of a threat event

In general, the *likelihood* of a threat event should be a score based on a combination of factors. For example, any available evidence that you have, prior experience, and your expert judgment.

Consider the intent/capabilities of a threat source and potential threat events when producing a likelihood score.

Qualitative values	Quantitative values	Description
High	3	Threat source is almost certain to initiate a security event. An event could have multiple, severe, or catastrophic effects on business operations and assets.
Moderate	2	Threat source is somewhat likely to initiate a security event. An event could significantly reduce the functionality of organizational operations and assets.
Low	1	Threat source is highly unlikely to initiate a security event. An event could have minor, negligible effects on business operations and assets.

Severity of a threat event

In general, the *severity* of a threat event is a measure of its potential impact to business operations. For example, would the event cause a business function to stop entirely? Might it temporarily disrupt a business process and go unnoticed?

Consider the business impact of *threat events* when producing a severity score.

Qualitative values	Quantitative values	Description
High	3	Threat source is almost certain to initiate a security event. An event could have multiple, severe, or catastrophic effects on business operations and assets.
Moderate	2	Threat source is somewhat likely to initiate a security event. An event could significantly reduce the functionality of organizational operations and assets.
Low	1	Threat source is highly unlikely to initiate a security event. An event could have minor, negligible effects on business operations and assets.

NIST SP 800-30 Rev SP

NIST SP 800-30 Rev. 1

Guía para la evaluación de riesgos

La publicación NIST SP 800-30 ofrece orientación sobre cómo llevar a cabo evaluaciones de riesgos. Describe estrategias para identificar, analizar y remediar los riesgos. Las organizaciones utilizan la NIST SP 800-30 para conocer la probabilidad e intensidad de los riesgos potenciales, lo que les permite tomar decisiones informadas sobre la asignación de recursos, la implementación de controles y la priorización de los esfuerzos de mitigación.

Este documento de cuatro páginas está adaptado de la publicación NIST SP 800-30 Rev. 1. El término "Rev. 1" indica que se trata de la primera versión actualizada de esta publicación. El NIST revisa sus documentos de forma periódica para incorporar nueva información, reflejar cambios tecnológicos y requisitos normativos, o bien atender sugerencias y comentarios.

Nota: El [Centro de Recursos de Seguridad Informática](#) del NIST contiene más información sobre la publicación SP 800-30 Rev. 1.

Fuentes de amenazas

La publicación NIST SP 800-30 define y clasifica las fuentes de amenazas como entidades o circunstancias que pueden impactar negativamente en los sistemas de información de una organización. Esta información resulta útil para identificar y evaluar riesgos potenciales. Al tomarla como referencia, considere la intención y las capacidades de las fuentes de amenazas, tanto internas como externas.

Nota: La siguiente tabla enumera algunas posibles *fuentes de amenazas* que podrían comprometer un servidor de base de datos de acceso público.

Tipo	Ejemplos	Descripción
Human	<i>Usuario estándar</i> • Empleado • Cliente <i>Usuario privilegiado</i> • Administrador del sistema <i>Grupo</i> • Competidor • Proveedor • Socio comercial • Estado nación <i>Persona ajena / Externa</i> • Hacker • Hactivista • Amenaza persistente avanzada (APT)	Amenazas derivadas de individuos o grupos que podrían explotar recursos cibernéticos de forma deliberada o accidental. Por ejemplo, podrían alterar datos de manera que afecte negativamente a la empresa. De igual forma, podrían robar datos intencionadamente y dañar el equipamiento de la empresa.
Technological	<i>Hardware</i> • Almacenamiento • Procesamiento • Comunicaciones <i>Software</i> • Sistema(s) operativo(s) • Redes • Software malicioso	Amenazas originadas por factores no humanos. Por ejemplo, fallos en los equipos debido al envejecimiento, el agotamiento de recursos u otras circunstancias.
Environmental	<i>Entorno operativo</i> • Controles de temperatura • Controles de humedad • Fuentes de alimentación defectuosas <i>Riesgos naturales</i> • Cortes de energía • Fenómenos meteorológicos extremos	Amenazas derivadas de factores accidentales no humanos. Por ejemplo, fallos en el equipamiento causados por el entorno operativo.

Eventos de amenaza

La publicación NIST SP 800-30 define y clasifica los eventos de amenaza como situaciones reales en las que una fuente de amenaza explota una vulnerabilidad y causa daños o perjuicios a los sistemas de información de una organización. Esta información es útil para comprender los tipos de riesgos a los que están expuestos los activos. Al comprender los posibles eventos de amenaza, se pueden definir controles y contramedidas más eficaces.

Nota: La siguiente tabla enumera sólo algunos de los posibles *eventos de amenaza* que podrían comprometer un servidor de base de datos de acceso público.

Ejemplos	Descripción
Realizar reconocimiento y vigilancia de la organización.	La fuente de amenaza examina y evalúa las vulnerabilidades de la empresa a lo largo del tiempo utilizando diversas herramientas (por ejemplo, escaneo, observación física).
Obtener información confidencial mediante exfiltración.	La fuente de amenaza instala software malicioso en los sistemas de la organización para localizar y adquirir información sensible.
Alterar o eliminar información crítica.	La fuente de amenaza altera o elimina datos esenciales para las operaciones cotidianas del negocio.
Crear certificados falsificados.	La fuente de amenaza compromete a una autoridad de certificación para que sus conexiones parezcan legítimas.
Instalar analizadores de red (sniffers) dirigidos y de carácter persistente en los sistemas de información de la organización.	La fuente de amenaza instala software diseñado para capturar y recopilar (sniffing) el tráfico de red de forma continua durante un período prolongado.
Llevar a cabo ataques de Denegación de Servicio (DoS).	La fuente de amenaza envía solicitudes excesivas y automatizadas para colapsar la capacidad operativa del sistema.
Interrumpir operaciones críticas para la misión.	La fuente de amenaza compromete la integridad de la información imposibilitando que la empresa lleve a cabo operaciones fundamentales.
Ofuscar ataques futuros.	La fuente de amenaza realiza acciones para obstaculizar la eficacia de los sistemas de detección de intrusiones o las capacidades de auditoría de la empresa.
Realizar ataques de tipo "man-in-the-middle" (hombre en el medio).	La fuente de amenaza intercepta y escucha las sesiones entre los sistemas internos y externos. Posteriormente, retransmite los mensajes entre dichos sistemas, haciendo creer a ambas partes

	que se comunican directamente a través de una conexión privada.
--	---

Probabilidad de un evento de amenaza

En general, la *probabilidad* de que ocurra un evento de amenaza debe ser una puntuación basada en la combinación de varios factores. Por ejemplo, la evidencia disponible, la experiencia previa y el juicio de expertos.

Tenga en cuenta la intención y las capacidades de la fuente de amenaza, así como los posibles eventos de amenaza al calcular la puntuación de probabilidad.

Valores cualitativos	Valores cuantitativos	Descripción
Alto	3	Es casi seguro que la fuente de amenaza desencadene un evento de seguridad. Un evento podría provocar efectos múltiples, graves o catastróficos en los activos y operaciones del negocio.
Moderado	2	Es algo probable que la fuente de amenaza desencadene un evento de seguridad. Un evento podría reducir significativamente la funcionalidad de los activos y operaciones de la organización.
Bajo	1	Es muy poco probable que la fuente de amenaza desencadene un evento de seguridad. Un evento tendría efectos menores o insignificantes en las operaciones y activos del negocio.

Severidad de un evento de amenaza

En general, la *severidad* de un evento de amenaza mide su impacto potencial en las operaciones del negocio. Por ejemplo, ¿el evento haría que una función del negocio se detuviera por completo? ¿Podría interrumpir temporalmente un proceso comercial sin que nadie lo note?

Tenga en cuenta el impacto comercial de los *eventos de amenaza* al calcular la puntuación de severidad.

Valores cualitativos	Valores cuantitativos	Descripción
Alto	3	Es casi seguro que la fuente de amenaza desencadene un evento de seguridad. Un evento podría provocar efectos múltiples, graves o catastróficos en los activos y operaciones del negocio.
Moderado	2	Es algo probable que la fuente de amenaza desencadene un evento de seguridad. Un evento podría reducir significativamente la funcionalidad de los activos y operaciones de la organización.
Bajo	1	Es muy poco probable que la fuente de amenaza desencadene un evento de seguridad. Un evento tendría efectos menores o insignificantes en las operaciones y activos del negocio.